

VirtuEx 시스템 감사 보고서 (6차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 6차 감사 (종합 심층 감사) 작성일: 2026-03-02 작성: 시스템 감사팀

1. 개요

6차 감사는 VirtuEx 프로젝트 전체를 대상으로 한 **종합 심층 감사**입니다. 백엔드 8개 마이크로서비스, 프론트엔드 Next.js 15 애플리케이션, 인프라/Docker 구성, 보안, 데이터 무결성, UX/접근성, 모바일 호환성 등 전 영역을 코드 레벨에서 검사했습니다.

1.1 감사 범위

영역	검사 항목	발견 이슈
보안 — 인증/인가	JWT, 2FA, RBAC, 서비스 간 인증	11건
보안 — 입력 검증	DTO, 파라미터, WebSocket	8건
데이터 무결성	트랜잭션, 레이스 컨디션, 이벤트 일관성	10건
인프라/배포	Docker, Kafka, Redis, 모니터링	9건
프론트엔드 — 접근성/UX	ARIA, 키보드, 모바일, 반응형	12건
프론트엔드 — 코드 품질	TypeScript, 에러 처리, 최적화	10건
프론트엔드 — SEO/성능	메타데이터, 이미지, 번들	8건
성능/확장성	캐시, 쿼리, 메모리	7건
합계		75건

2. 보안 감사 — 인증/인가 (11건)

#	위험도	항목	위치
1	상	JWT 폴백 인증 우회	jwt.strategy.ts:57-68
2	상	주민번호 암호화 솔트 하드코딩	resident-number.vo.ts
3	상	SMS 인증코드 비암호학적 난수	sms-verification.service.ts:24
4	중	로그인 레이트 리밋 부재	auth-proxy.controller.ts
5	중	주문 API 레이트 리밋 부재	api-gateway 전반
6	중	회원가입 레이트 리밋 약함	auth-proxy.controller.ts:25
7	중	WS 익명 구독 IP 제한 없음	price.gateway.ts:23
8	중	사용자 상태 캐시 TTL 과다	jwt.strategy.ts:42-55
9	중	Admin assertAdmin() 불일관	admin.controller.ts:29
10	하	PW 리셋 시 잠금 계정 차단	auth.service.ts:406

11	● 하	내부 서비스 토큰 단일 시크릿	서비스 간 통신 전반
----	-----	------------------	-------------

상세 설명:

- #1: user-auth 장애 시 JWT 서명만으로 인증 통과 — 비활성화/잠긴 계정도 접근 가능. 503 반환 필요
- #2: 'virtuex-salt' 고정 솔트 사용 — 레코드별 랜덤 솔트로 변경 필요
- #3: Math.random() 사용 — crypto.randomInt(100000, 999999) 로 변경 필요
- #4: 로그인 API에 별도 레이트 리밋 없음 (글로벌 100req/min만) — 5req/min 개별 제한 필요
- #5: 주문 생성에 개별 쓰로틀 없음 — 매칭 엔진 스팸 공격 가능. 100req/min 제한 권장
- #6: 60초당 5회 허용 — 봇 계정 생성 가능. CAPTCHA 또는 일일 제한 추가 필요
- #7: 익명 클라이언트 최대 5채널 구독 가능 — IP당 연결 수 제한 필요
- #8: Redis 캐시 TTL 60초 — 비활성화 사용자 최대 1분 접근 가능. 15-30초 축소 권장
- #9: Guard + 메서드 내 수동 검사 혼용 — @Roles(ADMIN) 데코레이터 통일 필요
- #10: 의도된 설계 — 보안적으로 올바르나 안내 메시지 개선 권장
- #11: 모든 서비스 동일 INTERNAL_SERVICE_SECRET 사용 — 서비스별 분리 권장 (장기)

3. 보안 감사 — 입력 검증 (8건)

#	위험도	항목	위치
12	● 상	주문 가격/수량 길이 제한 없음	place-order.dto.ts
13	● 중	심볼 패턴 검증 없음	place-order.dto.ts:18
14	● 중	관리자 검색 파라미터 미검증	admin.controller.ts:44
15	● 중	페이지네이션 최대값 미제한	admin.controller.ts:42
16	● 중	입출금 최대 금액 제한 없음	deposit.dto.ts
17	● 하	WS 메시지 크기 제한 미확인	chat.gateway.ts
18	● 하	파일 업로드 타입 검증	uploads/ 디렉토리
19	● 하	Redis URL 내 비밀번호 노출	price-cache.service.ts:20

상세 설명:

- #12: @Matches 정규식만 적용 — 10,000자리 숫자로 파싱 DoS 가능. @MaxLength(50) 추가 필요
- #13: @IsString() @IsEmpty() 만 적용 — @Matches(/^[A-Z0-9-]{1,20}\$/) 패턴 필요
- #14: @Query('search') 에 길이/패턴 검증 없음 — @MaxLength(100) 추가 필요
- #15: limit 파라미터 상한 없음 — limit=10000 시 메모리 소진. @Max(100) 필요
- #16: @IsPositive() 만 적용 — 비정상 대량 입금 방지를 위해 상한 설정 필요
- #17: 채팅 메시지 최대 길이 서버 측 재검증 권장
- #18: 업로드 기능 사용 시 MIME 타입 + 확장자 이중 검증 필요
- #19: 연결 URL에 비밀번호 포함 — 로그 노출 가능. 별도 환경변수 분리 권장

4. 데이터 무결성 감사 (10건)

#	위험도	항목	위치
20	● 상	주문 취소 자금 해제 레이스 컨디션	order.service.ts:247

21	상	매도 주문 보유량 락 부재	order.service.ts:99
22	상	인메모리 오더북 초기화 경쟁	matching-engine.service.ts
23	중	이벤트 소싱 다중 이벤트 원자성	order-engine/domain/ 전반
24	중	먹등키 동시성 TOCTOU	schema.prisma:26
25	중	Portfolio 자금 예치/해제 트랜잭션 부재	balance.service.ts:94-150
26	중	Kafka 이벤트 유실 보상 부재	Kafka 소비자 전반
27	중	Holding Decimal(20,8) 정밀도 손실	portfolio/schema.prisma:29
28	하	거래 이력 불변성 미보장	portfolio/schema.prisma:50
29	하	매칭 엔진 동시성 처리	matching-engine.service.ts

상세 설명:

- **#20:** `releaseFunds()` 와 `orderRead.update()` 가 별도 실행 — 중간 크래시 시 예치금 잠김. 단일 트랜잭션 필요
- **#21:** `validateHoldings()` 검증 후 주문 생성 사이에 이중 매도 가능. 보유량 예약(reserve) 메커니즘 필요
- **#22:** `onModuleInit()` 완료 전 주문 유입 시 이중 매칭/누락 가능. Redis 기반 오더북 또는 원자적 초기화 필요
- **#23:** `match()` 에서 복수 이벤트 발행 — 부분 성공 시 상태 불일치. Saga 패턴 필요
- **#24:** `@unique` 존재하나 체크-후-생성에 TOCTOU 취약점. DB constraint 의존 upsert 패턴 필요
- **#25:** `deposit()` 은 `$transaction` 사용하나 `reserve/release` 는 미사용 — 이중 지출 가능
- **#26:** DLQ 토픽 존재하나 재처리 로직 미구현
- **#27:** `Decimal.js` 사용은 양호하나 DB 저장 시 8자리 절삭 — 누적 오차 가능
- **#28:** 트랜잭션 레코드 UPDATE 방지 장치 없음 — DB 트리거 또는 앱 레벨 불변성 보장 권장
- **#29:** `Node.js` 단일 스레드로 현재 안전하나 수평 확장 시 분산 락 필요

5. 인프라/배포 감사 (9건)

#	위험도	항목	위치
30	상	하드코딩 서비스 URL 폴백	order.service.ts:54-60
31	중	Kafka 단일 노드 + RF=1	create-topics.sh
32	중	API Gateway 타임아웃 10초	proxy.service.ts:38
33	중	Prometheus 메트릭 미구현	백엔드 서비스 전반
34	중	요청 ID 추적 부재	서비스 간 통신 전반
35	중	헬스체크 DB 프로빙 미포함	health.controller.ts
36	하	CI 보안 스캔 non-blocking	ci.yml
37	하	Docker 이미지 마이너 버전 미고정	docker-compose.yml
38	하	로그 로테이션 cron 의존	rotate-logs.sh

상세 설명:

- **#30:** `configService.get()` + `localhost` 기본값 — 프로덕션에서 환경변수 누락 시 로컬 연결. `getOrThrow()` 필요
- **#31:** 개발 환경 전용이나 프로덕션 시 최소 3노드 + RF=3 필수
- **#32:** 10초는 과도 — 5초 + Circuit Breaker 패턴 권장
- **#33:** `/metrics` 엔드포인트 없음 — `@nestjs/prometheus` 또는 커스텀 메트릭 필요
- **#34:** `x-request-id` 헤더 미전파 — 분산 추적 어려움. 미들웨어 추가 필요
- **#35:** TCP 포트 체크만 수행 — Prisma health indicator 추가 필요
- **#36:** `pnpm audit` 가 `continue-on-error: true` — 취약점 발견 시에도 빌드 통과
- **#37:** PostgreSQL 16-alpine, Redis 7-alpine 등 — 재현 가능 빌드를 위해 정확한 버전 지정 권장
- **#38:** cron 설정 누락 시 로그 무한 증가 — `systemd timer` 또는 `logrotate.d` 설정 권장

6. 프론트엔드 감사 — 접근성/UX (12건)

#	위험도	항목	위치
39	● 중	Input aria-invalid 누락	Input.tsx
40	● 중	실시간 가격 aria-live 부재	가격 컴포넌트 전반
41	● 중	reduced-motion 미지원	Header.tsx
42	● 중	모달 고정 너비 오버플로	일부 모달 컴포넌트
43	● 중	모바일 터치 영역 불일치	버튼/링크 전반
44	● 중	다크모드 대비 비율 미검증	전체 테마
45	● 하	이미지 alt 텍스트 누락	page.tsx:127-132
46	● 하	네비게이션 로딩 미표시	라우터 전환 전반
47	● 하	이미지 로딩 실패 폴백 부재	이미지 컴포넌트 전반
48	● 하	폼 인라인 에러 개선 필요	로그인/회원가입 폼
49	● 하	스크롤 위치 복원 미구현	목록 페이지 전반
50	● 하	Empty State UI 불일관	데이터 목록 전반

상세 설명:

- **#39:** 에러 상태에서 `aria-invalid="true"` 미설정 — 스크린 리더가 에러 인식 불가
- **#40:** 실시간 변동 가격에 `aria-live="polite"` 없음 — 스크린 리더 사용자에게 변경 미통보
- **#41:** 모바일 메뉴 애니메이션에 `motion-reduce`: 미적용 — 전정기관 장애 사용자 배려 필요
- **#42:** `w-[320px]` 고정값 — 280px 이하 화면 오버플로. `max-w-full` 추가 필요
- **#43:** 일부 인터랙티브 요소가 44x44px 최소 터치 영역 미충족
- **#44:** 일부 `text-text-quaternary` 요소의 WCAG AA 4.5:1 대비 비율 미충족 가능
- **#45:** 기술 스택 아이콘 이미지에 설명적 alt 텍스트 부재
- **#46:** 페이지 전환 시 로딩 인디케이터 없음 — 사용자 혼란 가능
- **#47:** 이미지 로드 실패 시 대체 UI/아이콘 미표시
- **#48:** 에러 메시지가 폼 하단에만 표시 — 필드별 인라인 에러로 개선 권장
- **#49:** 상세에서 목록 복귀 시 스크롤 위치 초기화 — UX 개선 필요
- **#50:** 데이터 없을 때 일러스트 + 안내 메시지 통일 필요

7. 프론트엔드 감사 — 코드 품질 (10건)

#	위험도	항목	위치
51	● 중	API 클라이언트 타임아웃 미설정	api.ts
52	● 중	에러 바운더리 페이지별 미적용	관리자 페이지 전반
53	● 중	next/image 미사용	page.tsx 등
54	● 중	네트워크 에러 재시도 미구현	API 클라이언트 전반
55	● 중	WS 메시지 큐 미구현	useWebSocket.ts
56	● 중	WS 하트비트 부재	WebSocket 혹은 전반
57	● 하	하드코딩 문자열	Header.tsx:114
58	● 하	Zustand immer 미사용	스토어 전반
59	● 하	as const 미사용 열거형	타입 정의 일부
60	● 하	QueryClient 인스턴스 관리	React Query 설정

상세 설명:

- **#51:** axios에 기본 timeout 없음 — 네트워크 장애 시 무한 대기. `timeout: 15000` 추가 필요
- **#52:** 루트 `error.tsx` 만 존재 — 주요 페이지별 `error.tsx` 추가 필요
- **#53:** 일반 `<img>` 태그 사용 — Next.js Image 컴포넌트로 자동 최적화 필요
- **#54:** 일시적 네트워크 오류 재시도 없음 — axios-retry 또는 React Query retry 필요
- **#55:** 연결 끊김 시 메시지 유실 — 재연결 후 밀린 데이터 요청 로직 필요
- **#56:** ping/pong 하트비트 없음 — 좀비 연결 감지 불가
- **#57:** "VirtuEx" 등 브랜드명 하드코딩 — i18n 키 또는 상수 분리 권장
- **#58:** 복잡한 상태 업데이트 시 불변성 보장을 위해 immer 미들웨어 도입 권장
- **#59:** 리터럴 타입 안전성을 위해 `as const` 어서션 활용 권장
- **#60:** 다중 QueryClient 생성 가능성 — 싱글톤 패턴 확인 필요

8. 프론트엔드 감사 — SEO/성능 (8건)

#	위험도	항목	위치
61	● 중	페이지별 메타데이터 부재	페이지 컴포넌트 전반
62	● 중	robots.txt 미구현	frontend/public/
63	● 중	sitemap.xml 미구현	frontend/public/
64	● 중	Next.js middleware 인증 미구현	frontend/src/
65	● 하	코드 스플리팅 명시적 구성 부재	전반
66	● 하	이미지 lazy loading 미명시	이미지 태그 전반
67	● 하	번들 크기 최적화 미검토	패키지 전반

68	● 하	캐시 헤더 설정 미확인	next.config.ts
----	-----	--------------	----------------

상세 설명:

- **#61:** Next.js 15의 `generateMetadata()` 미활용 — 각 페이지별 title/description 필요
- **#62:** 검색 엔진 크롤링 제어 파일 부재
- **#63:** SEO 사이트맵 부재 — `next-sitemap` 또는 동적 생성 필요
- **#64:** 클라이언트 측 AuthGuard만 사용 — 서버 미들웨어에서 인증 체크 추가 권장
- **#65:** `dynamic import` 일부 사용 — 더 많은 무거운 컴포넌트 분리 권장
- **#66:** `loading="lazy"` 속성 미설정 — 초기 로딩 성능 영향
- **#67:** `socket.io-client`, `recharts` 등 대형 번들 — `tree-shaking` 및 대안 검토 권장
- **#68:** 정적 자산에 대한 캐시 전략 미명시

9. 성능/확장성 감사 (7건)

#	위험도	항목	위치
69	● 중	매칭 엔진 단일 인스턴스	matching-engine.service.ts
70	● 중	가격 엔진 매직 넘버	market-data 서비스
71	● 중	SMS 코드 TTL 하드코딩	user-auth 서비스
72	● 하	거래 정산 최종 일관성 지연	Kafka 이벤트 전반
73	● 하	테스트 커버리지 부족	테스트 전반
74	● 하	PII 미암호화 저장	user-auth 스키마
75	● 하	HSTS 헤더 백엔드 미설정	api-gateway/main.ts

상세 설명:

- **#69:** 수평 확장 시 오더북 동기화 불가 — Redis 기반 공유 오더북 전환 필요 (장기)
- **#70:** `VOLATILITY_EVENT_PROBABILITY`, `DURATION_MS` 등 하드코딩 — 환경변수/설정 파일 분리 필요
- **#71:** `CODE_TTL = 180` (3분) 고정 — 환경변수로 설정 가능하도록 변경 필요
- **#72:** Kafka 비동기 정산 — 일시적 자금 "유실" 상태 가능. 사용자 안내 필요
- **#73:** 약 6개 테스트 파일 — 주요 비즈니스 로직 70%+ 커버리지 목표 권장
- **#74:** 주민번호는 암호화되거나 전화번호/이메일 평문 저장 — 필드 레벨 암호화 검토
- **#75:** Helmet에 HSTS 미포함 — `hsts: { maxAge: 31536000, preload: true }` 추가 권장

10. 종합 평가

10.1 위험도별 분류

위험도	건수	비율
● 상 (Critical)	8건	10.7%
● 중 (Medium)	38건	50.7%
● 하 (Low/Info)	29건	38.6%

합계	75건	100%
----	-----	------

10.2 영역별 성숙도

항목	점수	비고
인증/인가	3.5/5	JWT 구현 우수하나 토큰/레이트 리밋 미흡
입력 검증	3.5/5	DTO 패턴 양호하나 일부 길이/패턴 누락
데이터 무결성	3.0/5	트랜잭션/동시성 처리 보강 필요
인프라/배포	4.0/5	모니터링 스택 양호, 메트릭 엔드포인트 필요
프론트엔드 접근성/UX	3.0/5	기본 구조 양호하나 ARIA/모바일 개선 필요
프론트엔드 코드 품질	3.5/5	아키텍처 우수, 에러 처리/최적화 미흡
SEO/성능	2.5/5	메타데이터/사이트맵 등 기본 SEO 부재
성능/확장성	3.5/5	현재 규모 적절, 확장 대비 설계 필요
종합	3.3/5	

10.3 누적 감사 현황

차수	유형	발견	수정	스킵	미수정
1차	신규 감사	36	36	0	0
2차	신규 감사	50	45	4	1
3차	수정 검증	0	-	-	-
4차	신규 감사	79	79	0	0
5차	수정 검증	0	-	-	-
6차	종합 심층 감사	75	미수정	0	75
누적		240	160	4	76

10.4 즉시 수정 권장 사항 (상 위험도 8건)

1. JWT 토큰 인증 우회 — user-auth 서비스 장애 시 503 반환으로 변경
2. 주민번호 솔트 하드코딩 — 레코드별 랜덤 솔트 생성
3. SMS 코드 비암호화적 난수 — `crypto.randomInt()` 사용
4. 주문 가격/수량 DoS — `@MaxLength(50)` 추가
5. 주문 취소 자금 해제 레이스 컨디션 — 트랜잭션 래핑
6. 매도 주문 보유량 이중 지출 — 보유량 예약 메커니즘 구현
7. 인메모리 오더북 초기화 경쟁 — 원자적 초기화 또는 Redis 전환
8. 서비스 URL 하드코딩 토큰 — `getOrThrow()` 사용

10.5 프로젝트 강점

- 마이크로서비스 아키텍처: 8개 서비스 분리 + CQRS/이벤트 소싱 패턴 적용

- 인증 체계: JWT + 2FA(TOTP) + 계정 잠금 + timing-safe 비교
- 인프라 구성: Docker Compose + Prometheus + Grafana + Jaeger 모니터링
- 프론트엔드 설계: Zustand + React Query 조합, WebSocket 실시간 가격
- 코드 품질: TypeScript strict 모드, ESLint, Prettier, Husky 적용
- i18n 지원: 한국어/영어 다국어 구현 완료
- DB 설계: UUID 기반 ID, 적절한 인덱싱, Cascade 삭제

10.6 결론

VirtuEx 프로젝트는 마이크로서비스 아키텍처, 이벤트 소싱, CQRS 등 고급 설계 패턴을 적용한 우수한 구조를 갖추고 있습니다. 1~5차 감사를 통해 160건의 이슈가 수정되어 전반적인 품질이 크게 향상되었습니다.

본 6차 종합 심층 감사에서는 75건의 신규 이슈를 발견했으며, 특히 **금융 트랜잭션 안전성**(레이스 컨디션, 이중 지출), **인증 폴백 취약점**, **프론트엔드 접근성/UX** 영역에서 개선이 필요합니다. 상 위험도 8건은 즉시 수정을 권장하며, 중 위험도 38건은 단기(1-2주) 내 해결을 권장합니다.

본 보고서는 VirtuEx 시스템의 6차 종합 심층 감사 결과입니다. 2026-03-02 기준 소스 코드를 대상으로 합니다.